CO1 - AT-3 - Assignment (Ethical Hacking)

ITA0403

Name: D.K.sumalatha

Reg.NO: 192424023

17) A client asks you to test only some departments. But you think the departments they did not include may have the biggest security problems, possibly because the managers are hiding them.

Solution:-

Ethical Tension Between contractual Boundaries and professional Duty.

In this situation, the client has clearly asked the security professional to test only certain departments. However, the professional strongly suspects that the departments excluded from the scope contain the greatest security risks, possibly because executive, intentionally excluded them.

This creates an ethical conflict between following the contract and protecting the organization.

1) contractual Responsibility.

The first responsibility of a security professional is to follow the agreed scope of work. If the contract says certain departments are excluded, the professional should not test those systems without permission,

Unauthorized testing could:

Violate the contract.

cause system damage or service.

Scanned with OKEN Scanner

create legal problems.
Affect employee privacy
Damage the trust between the client and se
professional.

Therefore, the professional should not secretly test the excluded Departments.

2) Professional Responsibility.

At the same time, a security professional has a duty to help protect the organization from serious security threats.

If there is strong evidence that the excluded departments have major vulnerabilities, simply ignoring the concern may also be ethically wrong. A serious Vulnerability could lead to.

- Data theft
- Financial loss
- privacy breaches
- Malware or ransomware attacks
- Damage to the organization's reputation.

3) The Ethical solution:-

The professional should not break the Contract but should also not ignore the suspected risk.

The correct approach is,

Identify the concern → Document it → Inform the authorized client Representative → Request permission → Expand the testing scope if approved.

Scanned with OKEN Scanner

If the client refuses, the professional should continue working only within the authorized scope and document the concern appropriately.

If there is evidence of deliberate concealment or a serious legal/safety issue, the professional should follow the organization's formal escalation, compliance, legal or responsible - disclosure procedure rather than taking unauthorized action.

A) Ethical principles Involved.

Principle	Meaning.
Authorization	Test only system which permission has been given
professional responsibility	Take genuine security risk seriously.
Confidentiality	Do not unnecessarily disclose sensitive information
Integrity	Be honest about risks and findings.
Non-maleficence	Avoid causing unnecessary harm to system or people.
Accountability	Document decisions and follow proper escalation procedures.

Scanned with OKEN Scanner

conclusion:-

The professional faces a difficult choice between contractual obedience and the duty to protect the organization. They ethical solution is not to secretly test the excluded departments. Instead, the professional should clearly communicate the suspected risk, provide evidence, request written authorized to expand the scope, and use proper escalation channels if necessary.

Scanned with OKEN Scanner